



亚奥理事会官方合作伙伴

OFFICIAL PRESTIGE PARTNER OF THE OLYMPIC COUNCIL OF ASIA

一、安全通告

近日，监测到cPanel 登录流程认证绕过漏洞（CVE-2026-41940），目前技术细节及PoC已公开，在 11.40 之后的 cPanel 和 WHM 版本中。

该产品主要使用客户行业分布广泛，漏洞危害性极高，建议客户尽快做好自查及防护。

已通过恒脑AI代码审计智能体复现此漏洞。

```
[0] hostname = 115-220-185-161.cprapid.com
[1] minting a preauth session...
    session base = :e6ilqg2MUGRtWbKG
[2] sending the CRLF injection (Basic auth + no-ob cookie)...
    HTTP 307, leaked token = /cpsess3708038035
[3] firing do_token_denied to propagate raw -> cache...
    HTTP 401, gadget fired
[4] verifying we're WHM root...
    /json-api/version -> HTTP 200 {"version":"11.126.0.53"}
[+] now just login to https://10.208.23.134:2087/ and use the terminal option to
```

二、漏洞信息

cPanel 是一套基于 Linux 的虚拟主机管理面板，提供网站和服务器管理功能。

漏洞标题	cPanel 登录流程认证绕过漏洞（CVE-2026-41940）
漏洞处置等级	1级

漏洞类型	认证漏洞
影响目标	
影响厂商	cPanel, Inc.
影响产品	cPanel, WHM
影响版本	cPanel & WHM 11.86.0 < 11.86.0.41, 11.110.0 < 11.110.0.97, 11.118.0 < 11.118.0.63, 11.126.0 < 11.126.0.54, 11.130.0 < 11.130.0.18, 11.132.0 < 11.132.0.29, 11.134.0 < 11.134.0.20, 11.136.0 < 11.136.0.5; WP Squared 11.136.1 < 11.136.1.7
安全版本	cPanel & WHM 11.86.0.41 / 11.110.0.97 / 11.118.0.63 / 11.126.0.54 / 11.130.0.18 / 11.132.0.29 / 11.134.0.20 / 11.136.0.5; WP Squared 11.136.1.7
漏洞编号	
CVE编号	CVE-2026-41940
CNVD编号	未分配
CNNVD编号	未分配
CVSS3.1评分	9.8
漏洞危害等级	严重
CVSS向量	
访问途径 (AV)	网络
攻击复杂度 (AC)	低
所需权限 (PR)	无需任何权限
用户交互 (UI)	不需要用户交互
影响范围 (S)	不变
机密性影响 (C)	高

完整性影响 (I)	高
可用性影响 (A)	高
威胁状态	
Poc情况	已发现
Exp情况	未发现
在野利用	未发现
研究情况	分析中

三、修复方案

官方修复方案

cPanel 官方已发布安全更新，请升级至对应版本线的修复版本：cPanel & WHM 请升级至 11.86.0.41、11.110.0.97、11.118.0.63、11.126.0.54、11.130.0.18、11.132.0.29、11.134.0.20 或 11.136.0.5（含以上）；WP Squared 请升级至 11.136.1.7（含以上）。

信息来源：<https://support.cpanel.net/hc/en-us/articles/40073787579671-cPanel-WHM-Security-Update-04-28-2026>

临时缓解方案

在官方补丁安装前，建议采取以下临时缓解措施：1）对 cPanel/WHM 管理界面实施严格的 IP 白名单访问控制，仅允许可信管理 IP 访问 2082/2083（cPanel）、2086/2087（WHM）端口；2）如非必要，不要在公网暴露 cPanel/WHM 管理端口，建议通过 VPN 或堡垒机进行管理；3）部署 WAF 规则，对登录接口的异常请求进行监控和拦截。以上措施为基于漏洞暴露面的保守缓解，无法完全消除风险。

信息来源：<https://www.vulncheck.com/advisories/cpanel-and-whm-authentication-bypass-via-login-flow>

四、参考资料

<https://support.cpanel.net/hc/en-us/articles/40073787579671-cPanel-WHM-Security-Update-04-28-2026>

<https://docs.cpanel.net/release-notes/release-notes>

<https://docs.wpsquared.com/changelogs/versions/changelog/#13617>

<https://www.vulncheck.com/advisories/cpanel-and-whm-authentication-bypass-via-login-flow>

<https://www.namecheap.com/status-updates/ongoing-critical-security-vulnerability-in-cpanel-april-28-2026>

<https://github.com/Sachinart/CVE-2026-41940-cpanel-0day>

<https://github.com/watchtowerlabs/watchTower-vs-cPanel-WHM-AuthBypass-to-RCE.py>